

Question 1 [20 points] (Source: Question 1 of 24-25-Resit)

Imagine you are a network security engineer responsible for maintaining the security of an e-commerce website. Recently, the website suffered an SQL injection attack, leading to the leakage of some user data. To address this issue, you need to analyze the SQL injection attack and propose corresponding preventive measures.

- a. Analyze the following SQL query and identify the SQL injection vulnerability: **(10 points)**

```
SELECT *  
FROM users  
WHERE username = '$_GET["username"]' AND password = '$_GET["password"]';
```

- b. Present malicious user inputs exploiting the vulnerability. **(5 points)**
- c. Explain which of CIA is/are obviously violated in the SQL injection attack in question 1.b. **(5 points)**

Question 2 [20 points] (Source: Question 2 of 24-25-Resit)

An intrusion detection system (IDS) is a device or software application that monitors a network or systems for malicious activity or policy violations. Table 1 shows a testing result of an intrusion detection system. The test includes 10 events (a-j). The “Test” row shows the testing result for each event, where “1” denotes a malicious activity detected and “0” indicates no malicious activity detected. The “Truth” row shows the ground truth if the corresponding event includes a malicious activity or not, “0” means no while “1” means yes.

Table 1.

Event	a	b	c	d	e	f	g	h	i	j
Test	0	1	1	1	0	0	0	0	0	1
Truth	1	0	0	1	0	0	1	0	0	0

- a. Please present the concept of signature-based intrusion detection, and explain why it suffers false negative. **(6 points)**
- b. Please present the concept of anomaly-based intrusion detection, and explain why it suffers false positive. **(6 points)**
- c. Please count the number of false negative, false positive, true negative, and true positive respectively in terms of Table 1. Hint: the sum of the numbers should be 10. **(8 points)**

Question 3 [20 points] (Source: Question 3 of 24-25-Final)

A high-tech company utilizes an Enterprise Content Management (ECM) system to manage and approve documents. As shown in Figure 1, the process is as follows: after the document is drafted by an author, it is uploaded to the system. The document then undergoes a sequential approval process by the department head, regional leader, and the chairman. It is required that a document be viewed by only the four individuals and be modified by only the author. However, due to a vulnerability in the system's access control, coupled with the fact that the files are stored without encryption, a secret document has become accessible to several other individuals (e.g., system administrators, IT support technician, etc.) as well. This has led to the leakage of several secret documents.

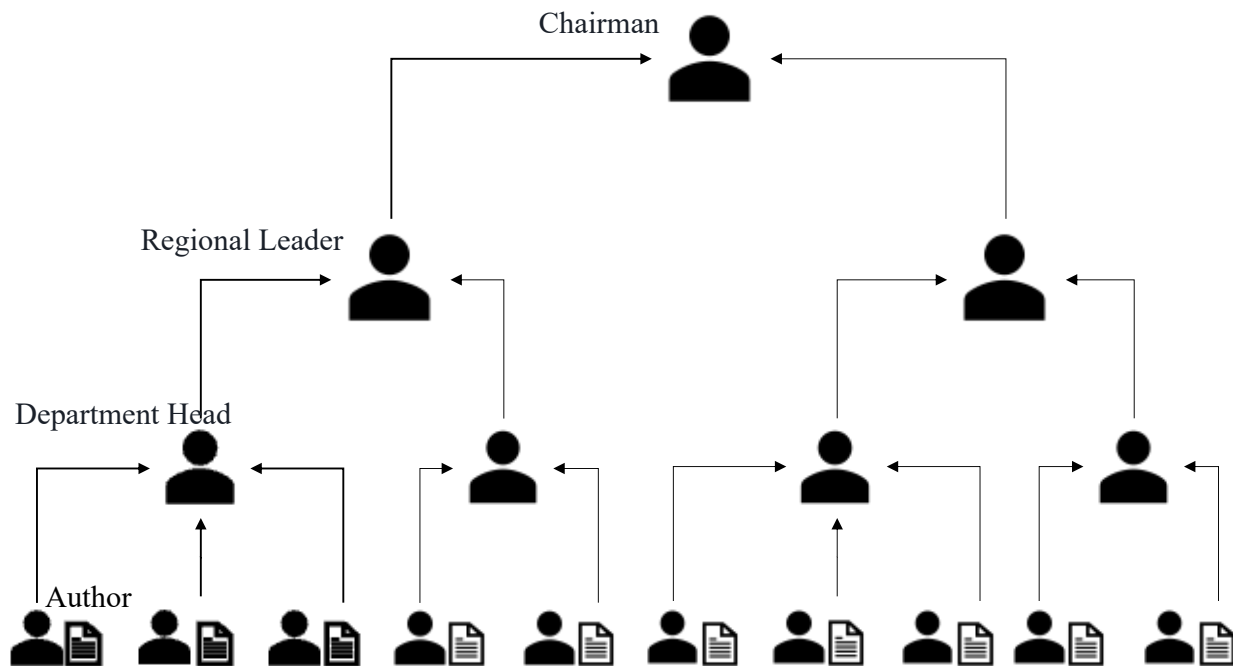


Figure 1. Process for a file being processed in the system.

- To deal with leakage, the company requires staff members use passwords to protect their documents before they (as authors) upload the documents to the system, and then securely share the password to the other three individuals who are involved in the approval process. Discuss three shortcomings of this approach. **(6 points)**
- Detail your own methods to address leakage issue and explain how the issue is addressed. **(14 points)**